



READ-ONLY SECURITY ASSESSMENT

Vulnerability Assessment Report

Read-Only Security Assessment of Nmap Public Web Infrastructure

PREPARED BY Pratyush Singh Rathore
ASSESSMENT DATES 23-24 June 2026
PROJECT Future Interns — Cyber Security Task 1 (2026)
ENGAGEMENT TYPE Passive Assessment Only

PASSIVE ASSESSMENT ONLY · NO EXPLOITATION PERFORMED
NO BRUTE FORCE · NO DATA EXTRACTION · NO DESTRUCTIVE ACTIVITY

Passive and read-only assessment. No exploitation was performed.

Document Control & Disclaimer

Document Control

Prepared by	Pratyush Singh Rathore
Assessment date	23-24 June 2026
Assessment type	Passive, read-only security assessment
Network target	scanme.nmap.org
Web target (HTTP headers)	http://scanme.nmap.org/
Web target (ZAP passive browsing)	https://nmap.org/
Tools used	Nmap 7.99 · SecurityHeaders by Snyk · OWASP ZAP 2.17.0

Disclaimer

This assessment was limited to publicly accessible information, basic port discovery, HTTP security-header analysis and passive OWASP ZAP inspection.

No brute force, exploitation, authentication bypass, denial-of-service testing, payload injection, data extraction or destructive activity was performed.

Executive Summary

Between 23 and 24 June 2026, a passive, read-only security assessment was performed against the public Nmap project infrastructure. The assessment combined basic network port discovery, HTTP response-header analysis and passive browser-traffic inspection. No exploitation, authentication bypass or destructive testing was attempted at any stage.

- Publicly exposed network services were identified on scanme.nmap.org through basic TCP port discovery.
- Multiple browser security headers were absent on the scanme.nmap.org web target, resulting in a failing grade from an automated header scanner.
- scanme.nmap.org was accessible over plain HTTP without an automatic redirection to HTTPS.
- Server software details (Apache version and operating system) were publicly visible in HTTP response headers.
- OWASP ZAP produced a set of passive observations while browsing nmap.org, including missing-header and hardening-related alerts.
- Several ZAP alerts originated from third-party Google services (Analytics, Tag Manager, googleapis.com) reached while loading nmap.org, and were treated separately from findings attributable to nmap.org itself.
- No critical or confirmed high-severity vulnerability was demonstrated during this engagement.

0 CONFIRMED CRITICAL/HIGH	3 MEDIUM HARDENING ITEMS	4 LOW HARDENING ITEMS	Multiple THIRD-PARTY OBSERVATIONS
--	---------------------------------------	---------------------------------	--

Scope and Methodology

In Scope

- Public pages on the target web infrastructure
- Basic port discovery against scanme.nmap.org
- HTTP security-header inspection
- Passive browser traffic analysis using OWASP ZAP
- Server banner observation

Out of Scope

- Login bypass
- SQL injection attempts
- Brute force attacks
- Active exploitation
- Denial of Service testing
- Data extraction

Limitations

- Findings reflect a single point-in-time, read-only assessment and do not represent a complete security audit.
- Passive scanner alerts (OWASP ZAP) require manual validation and are not proof of an exploitable vulnerability.
- Some observations relate to third-party Google services loaded while browsing nmap.org and may not be directly attributable to the nmap.org infrastructure.

Assessment Workflow

Target Selection	Nmap Scan	Header Analysis	ZAP Passive Scan	Report
------------------	-----------	-----------------	------------------	--------

Nmap Network Scan

A basic TCP port scan was executed against the network target scanme.nmap.org using Nmap 7.99. The scan performed standard port discovery only; no service exploitation, vulnerability scripts or intrusive scan techniques were used.

```
((base) pratyushsingh@Mac ~ % nmap scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-23 23:58 +0530
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.30s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe10:bb2f
Not shown: 992 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    filtered smtp
80/tcp    open  http
135/tcp    filtered msrpc
139/tcp    filtered netbios-ssn
445/tcp    filtered microsoft-ds
9929/tcp   open  nping-echo
31337/tcp  open  Elite

Nmap done: 1 IP address (1 host up) scanned in 74.92 seconds
((base) pratyushsingh@Mac ~ %
```

Figure 1: Nmap basic TCP scan of scanme.nmap.org.

Port Summary

Port	State	Service
22	Open	SSH
25	Filtered	SMTP
80	Open	HTTP
135	Filtered	MSRPC
139	Filtered	NetBIOS-SSN
445	Filtered	Microsoft-DS
9929	Open	Nping Echo
31337	Open	Nmap service label: Elite

An open port is an exposed service, not automatically a vulnerability. Confirming risk requires further validation of the underlying service version, configuration and exposure context.

Risk classification: **INFORMATIONAL**

Security Headers Overview

The web target <http://scanme.nmap.org/> was assessed using SecurityHeaders by Snyk, a passive HTTP response-header analysis tool. The scan returned an overall grade of F, driven primarily by the absence of several recommended browser security headers.

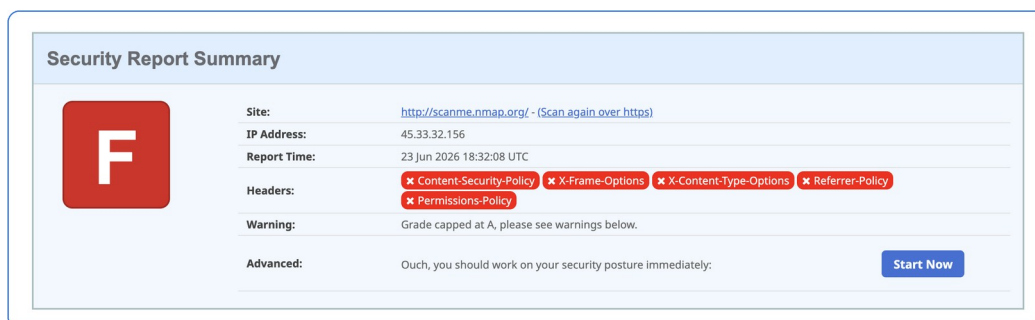


Figure 2: SecurityHeaders assessment showing Grade F and missing headers.

Summary of Header-Related Findings

Finding	Severity
Missing Content-Security-Policy	MEDIUM
Missing X-Frame-Options	MEDIUM
HTTP without HTTPS redirect	MEDIUM
Missing X-Content-Type-Options	LOW
Missing Referrer-Policy	LOW
Missing Permissions-Policy	LOW
Server version disclosure	LOW

The overall Grade F is a composite scoring label produced by the scanning tool. It reflects the combined absence of several headers below and is not treated in this report as a separate, independent high-risk finding.

HTTP and Server Information Evidence

The raw HTTP response headers returned by scanme.nmap.org confirm that the site was served over plain HTTP without an automatic redirect to HTTPS, and that the web server publicly discloses its software name and version.

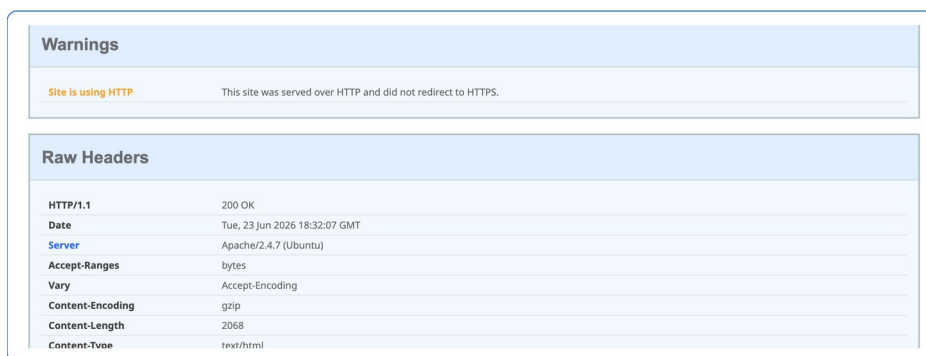


Figure 3: HTTP warning and server-version disclosure in response headers.

SH-01 HTTP without HTTPS Redirection

SEVERITY: MEDIUM

DESCRIPTION

The target was served over HTTP and did not automatically redirect the browser to an HTTPS connection.

IMPACT

Traffic between the client and server may travel unencrypted, exposing it to interception or tampering on untrusted networks.

SH-02 Server Version Information Disclosure

SEVERITY: LOW

DESCRIPTION

The Server response header discloses the web server software and version (Apache/2.4.7 on Ubuntu).

IMPACT

Version disclosure can help an attacker narrow down known vulnerabilities associated with a specific software version, though it does not by itself confirm exploitability.

Recommendations

- Redirect all HTTP requests to HTTPS.
- Enable HTTP Strict Transport Security (HSTS) once HTTPS is fully and correctly configured.
- Minimise the level of detail exposed in the Server response header.
- Keep server software patched and up to date.

Missing Content Security Policy

Both the SecurityHeaders scan and the OWASP ZAP passive scan independently flagged the absence of a Content-Security-Policy (CSP) response header.

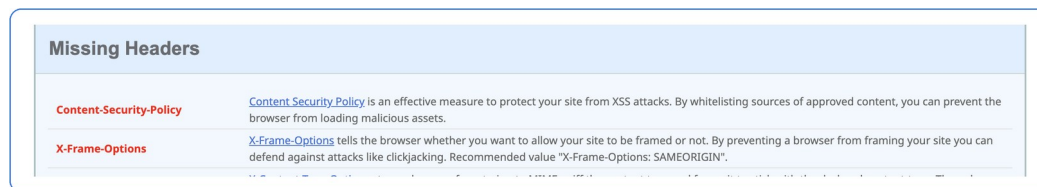


Figure 4: Missing Content-Security-Policy header.

SH-03 Missing Content-Security-Policy Header

SEVERITY: MEDIUM

DESCRIPTION

The application does not return a Content-Security-Policy header.

IMPACT

A missing CSP reduces browser-side defence against script and content injection. It does not, by itself, prove that a cross-site scripting (XSS) vulnerability exists.

RECOMMENDATION

Content-Security-Policy: default-src 'self'; object-src 'none'; base-uri 'self'; frame-ancestors 'self';

Missing Anti-Clickjacking Protection

OWASP ZAP raised a passive alert indicating that a response did not include anti-framing protection. The example below was observed on a third-party Google API endpoint reached while browsing nmap.org.

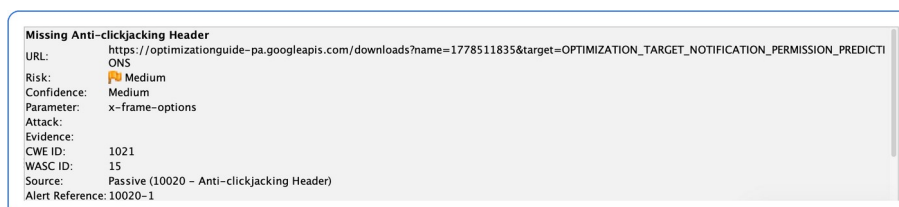


Figure 5: OWASP ZAP passive alert for missing anti-clickjacking protection (third-party endpoint example).

The evidence URL for this particular alert instance belongs to *googleapis.com*. It is labelled here as a third-party endpoint example and is not attributed directly to *nmap.org*. Other instances of this alert class were also observed; each must be assessed against its own evidence URL.

SH-04 Missing Anti-Clickjacking Header

SEVERITY: MEDIUM

DESCRIPTION

Anti-framing protection was not detected on the affected response.

IMPACT

The page may be embedded inside another site and used in clickjacking-style attacks, where a user is tricked into interacting with hidden or disguised UI elements.

RECOMMENDATION

X-Frame-Options: SAMEORIGIN
or: *Content-Security-Policy: frame-ancestors 'self';*

Additional Security Header Findings

The SecurityHeaders scan also identified the following lower-severity hardening gaps. Each represents a missing defence-in-depth browser header rather than a directly exploitable vulnerability.

X-Content-Type-Options	X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".
Referrer-Policy	Referrer-Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.
Permissions-Policy	Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Figure 6: Additional missing browser security headers.

SH-05 Missing X-Content-Type-Options

SEVERITY: LOW

RECOMMENDATION

X-Content-Type-Options: nosniff

SH-06 Missing Referrer-Policy

SEVERITY: LOW

RECOMMENDATION

Referrer-Policy: strict-origin-when-cross-origin

SH-07 Missing Permissions-Policy

SEVERITY: LOW

RECOMMENDATION

Permissions-Policy: camera=(), microphone=(), geolocation=()

OWASP ZAP Passive Scan Overview

OWASP ZAP 2.17.0 was used only in passive mode. Browser traffic was captured while manually exploring public pages on <https://nmap.org/>. No active scan or attack payload was executed at any point during this assessment.

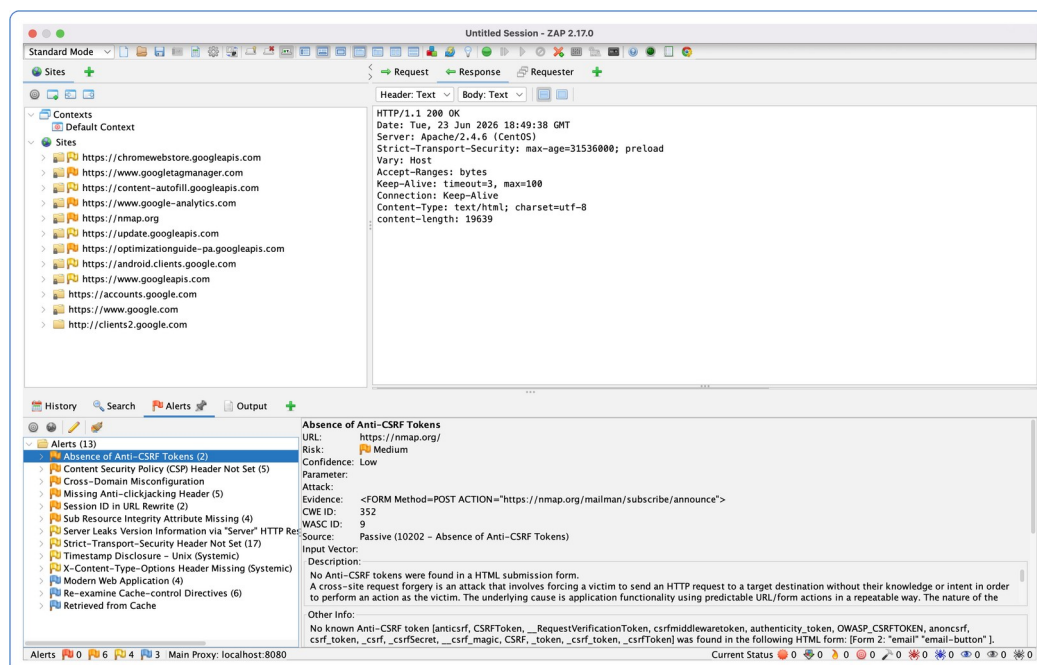


Figure 7: OWASP ZAP passive scan overview after browsing nmap.org.

Alert Categories Observed

- Absence of Anti-CSRF Tokens
- CSP Header Not Set
- Cross-Domain Misconfiguration
- Missing Anti-clickjacking Header
- Session ID in URL Rewrite
- Subresource Integrity Attribute Missing
- Server Version Information Disclosure
- HSTS Header Not Set
- X-Content-Type-Options Header Missing

Several alerts were generated for third-party Google resources (Google Analytics, Google Tag Manager, googleapis.com) loaded as part of nmap.org and are not directly attributed to nmap.org.

Anti-CSRF Observation

OWASP ZAP passively identified a POST-method HTML form on <https://nmap.org/> that did not contain a token matching any of the scanner's known anti-CSRF token patterns.



Figure 8: ZAP passive observation of a POST form without a recognised anti-CSRF token.

ZAP-01 Absence of Anti-CSRF Tokens

SEVERITY: MEDIUM — VALIDATION REQUIRED

DESCRIPTION

ZAP identified a POST form (the mailing-list subscribe form) without a token matching its known anti-CSRF patterns.

IMPACT

If the form performs a security-sensitive action, an attacker may attempt to submit unwanted requests on behalf of a user without their knowledge or intent.

IMPORTANT QUALIFICATION

This is a passive scanner observation and requires manual validation. The form may be public, unauthenticated, or protected through another mechanism not visible to a passive scan.

Recommendations

- Use unpredictable, server-validated CSRF tokens for state-changing authenticated actions.
- Use SameSite cookies where session state is involved.
- Validate the Origin or Referer header where appropriate.

Subresource Integrity Observation

OWASP ZAP flagged an external script reference on <https://nmap.org/> that does not carry a Subresource Integrity (SRI) attribute.



Figure 9: External resource referenced without an SRI integrity attribute.

ZAP-02 Subresource Integrity Attribute Missing

SEVERITY: MEDIUM — HARDENING OBSERVATION

EVIDENCE

External Google Analytics resource (google-analytics.com/analytics.js) referenced via a preload link without an integrity attribute.

DESCRIPTION

Subresource Integrity allows browsers to verify that a third-party resource matches an expected cryptographic hash before executing it.

IMPACT

If a third-party resource is modified or compromised at its source, malicious content could potentially be delivered to visitors without detection by the browser.

RECOMMENDATION

Use integrity and crossorigin attributes on externally hosted scripts and stylesheets where technically appropriate.

Some dynamically updated third-party scripts (such as analytics libraries that change frequently) may not be practical to pin using SRI and should be evaluated case by case.

Third-Party Observations & Conclusion

Third-Party Resource Observations

The following passive ZAP alerts were generated for Google Analytics, Google Tag Manager or googleapis.com resources loaded while browsing nmap.org. They are presented as third-party resource observations and are not attributed directly to the nmap.org infrastructure.



Cross-Domain Misconfig. —
googletagmanager.com



Session ID in URL — google-
analytics.com



Anti-clickjacking — googleapis.com

Figure 10: Passive ZAP alerts generated for Google Analytics, Google Tag Manager or googleapis.com resources.

Third-Party Observation Register

Alert	Host	Status
Cross-Domain Misconfiguration	googletagmanager.com	Third-party observation
Session ID in URL Rewrite	google-analytics.com	Likely analytics/tracking parameter; not a confirmed application session
Missing Anti-clickjacking Header	googleapis.com	Third-party observation
CSP Header Not Set	Verify visible endpoint before attribution	Context-dependent

Final Risk Summary

Confirmed Critical 0	Confirmed High 0
Medium Hardening Findings 3	Low Hardening Findings 4
Informational Network Observation 1	Passive ZAP Items Requiring Validation Multiple

Conclusion

The assessment identified several practical security-hardening opportunities, especially missing browser security headers, HTTP access without automatic HTTPS redirection, server-version disclosure and exposed network services.

OWASP ZAP generated additional passive alerts while browsing nmap.org. Alerts associated with Google Analytics, Google Tag Manager and googleapis.com were separated as third-party observations and were not presented as confirmed vulnerabilities in nmap.org.

No exploitation was performed and no confirmed critical or high-severity vulnerability was demonstrated.